

Protecție anti-DDoS & anti-bruteforce pentru Drupal

nginx · corelare de evenimente · Fail2Ban · nftables / iptables

PUBLIC / SANITIZED

ERNU.EU | IT & Security Solutions
14 septembrie 2026 · Versiunea 1.1

Cuprins

1. Implementare și arhitectură
2. Referință de configurare
3. Runbook operațional și rollback
4. Istoricul versiunilor

Documentația Markdown din repository rămâne sursa editabilă. Acest PDF este ediția distribuibilă, generată din aceleași documente la versiunea 1.1.

Ghid de implementare: protecție Drupal cu nginx și Fail2Ban

Versiune: 1.1 Data: 14 septembrie 2026 Brand: ERNU.EU | IT & Security Solutions

1. Scop și arhitectură

Soluția protejează un site Drupal 10/11 pe patru niveluri:

1. nftables sau iptables/ipset limitează flood-uri de bază la L3/L4;
2. nginx limitează cererile și conexiunile la L7;
3. security_log_processor.py corelează semnale slabe într-un scor per IP;
4. Fail2Ban transformă alertele validate în blocări temporare în kernel.

Un atac volumetric care saturează legătura trebuie oprit de provider, CDN sau serviciu de scrubbing. Configurația locală nu înlocuiește protecția upstream.

Fluxul implementat este:

```
Client -> firewall L3/L4 -> nginx L7 -> Drupal/PHP-FPM
      |
      v
    security-events.log
      |
      v
  security_log_processor.py
      |
      v
    security-alerts.log
      |
      v
      Fail2Ban
      |
      v
nftables sau iptables/ipset
```

2. Cerințe

Componentă	Recomandare
Drupal	10.x sau 11.x
nginx	1.22+ cu limit_req, limit_conn și realip
PHP-FPM	8.2/8.3, preferabil socket Unix
Fail2Ban	0.11+
Firewall	nftables 0.9.3+ sau iptables + ipset
Python	3.9+, fără pachete externe
Acces	root/sudo și o sesiune de recuperare separată

3. Pregătire sigură

- faceți backup pentru nginx, Fail2Ban și firewall;
- păstrați o sesiune SSH separată pentru rollback;
- adăugați IP-urile de administrare/monitorizare în ignoreip;
- identificați proxy-urile/CDN-urile de încredere înainte de activarea real IP;
- aplicați mai întâi în staging și observați logurile cel puțin un ciclu normal.

Nu acceptați X-Forwarded-For de la orice sursă. set_real_ip_from trebuie să conțină doar proxy-uri și intervale oficiale, actualizate.

4. Instalare

4.1 Alegeți un singur firewall

Varianta nftables, recomandată:

```
install -d -m 0755 /etc/nftables.d
install -m 0755 nftables/00-ddos-base.nft /etc/nftables.d/
nft -c -f /etc/nftables.d/00-ddos-base.nft
nft -f /etc/nftables.d/00-ddos-base.nft
```

Adăugați o singură dată în /etc/nftables.conf:

```
include "/etc/nftables.d/*.nft"
```

Alternativa iptables/ipset:

```
apt-get install -y ipset iptables-persistent
bash -n iptables/00-ddos-base-iptables.sh
bash iptables/00-ddos-base-iptables.sh
netfilter-persistent save
```

4.2 nginx

```
install -m 0644 nginx/conf.d/00-security-globals.conf /etc/nginx/conf.d/
install -m 0644 nginx/sites-available/drupal-site.conf /etc/nginx/sites-available/
ln -s /etc/nginx/sites-available/drupal-site.conf /etc/nginx/sites-enabled/
```

Activați 01-realip.conf numai după ce ați introdus sursele proxy/CDN de încredere. Modificați domeniul exemplu, document root, certificatul și socket-ul PHP-FPM, apoi:

```
nginx -t
systemctl reload nginx
```

4.3 Procesorul de securitate

```
install -d -m 0755 /opt/drupal-antiddos/scripts
install -m 0755 scripts/security_log_processor.py /opt/drupal-antiddos/scripts/
touch /var/log/nginx/security-events.log /var/log/nginx/security-alerts.log
chown www-data:adm /var/log/nginx/security-events.log /var/log/nginx/security-alerts.log
chmod 0640 /var/log/nginx/security-events.log /var/log/nginx/security-alerts.log
install -m 0644 systemd/drupal-security-processor.service /etc/systemd/system/
systemctl daemon-reload
systemctl enable --now drupal-security-processor
```

4.4 Fail2Ban

```
install -m 0644 fail2ban/filter.d/*.conf /etc/fail2ban/filter.d/
```

Pentru nftables:

```
install -m 0644 fail2ban/action.d/nftables-drupal-ban.conf /etc/fail2ban/action.d/
install -m 0644 fail2ban/jail.d/drupal-nginx.local /etc/fail2ban/jail.d/
```

Pentru iptables/ipset:

```
install -m 0644 fail2ban/action.d/iptables-drupal-ban.conf /etc/fail2ban/action.d/
install -m 0644 fail2ban/jail.d/drupal-nginx-iptables.local \
/etc/fail2ban/jail.d/drupal-nginx.local
```

Completați ignoreip, apoi validați și încărcați:

```
fail2ban-client -t
fail2ban-client reload
fail2ban-client status
```

5. Pipeline-ul de evenimente

nginx scrie numai cererile relevante în security-events.log. Procesorul menține o fereastră glisantă implicită de 60 de secunde și punctează User-Agent gol, scanare cunoscute, căi suspecte, semnături SQLi/XSS, răspunsuri 403/404, încercări de autentificare și rate mari. La scorul 12 generează o linie SECURITY_ALERT în security-alerts.log.

Fail2Ban citește alerta agregată cu maxretry = 1; blocarea este progresivă și poate ajunge până la o săptămână pentru recidiviști. În varianta nftables, fiecare jail folosește o tabelă proprie, astfel încât oprirea sa nu eliminează blocările altor jail-uri.

6. Testare controlată

```
python3 -m py_compile scripts/security_log_processor.py
bash -n scripts/test_attack_simulation.sh
bash -n iptables/00-ddos-base-iptables.sh
nginx -t
fail2ban-client -t
fail2ban-regex /var/log/nginx/security-alerts.log \
/etc/fail2ban/filter.d/drupal-security-events.conf
```

Rulați simularea numai asupra unui sistem propriu de staging:

```
./scripts/test_attack_simulation.sh https://staging.drupal.ernu.sec
```

Confirmați cronologic evenimentul brut, alerta agregată și banul:

```
tail -f /var/log/nginx/security-events.log /var/log/nginx/security-alerts.log
fail2ban-client status drupal-security-events
nft list table inet f2b_drupal_critical
# sau: ipset list drupal_critical
```

7. Monitorizare și rollback

Comenzi uzuale:

```
systemctl status drupal-security-processor fail2ban nginx
journalctl -u drupal-security-processor -f
fail2ban-client status drupal-security-events
```

Pentru unban controlat:

```
fail2ban-client set drupal-security-events unbanip 203.0.113.7
```

Rollback: dezactivați jail-urile adăugate, reîncărcați Fail2Ban, eliminați include-urile nginx după restaurarea backupului și restaurați regulile firewall anterioare. Nu goliți întreg firewall-ul pe un server accesat remote.

8. Mentenanță

- configurați logrotate cu create 0640 www-data adm pentru cele două loguri;
- revizuiți trimestrial pragurile pe baza traficului real și a fals-pozitivelor;
- actualizați intervalele CDN din sursa oficială;
- monitorizați spațiul pe disc, numărul de banuri și restarturile serviciului;
- retestați după upgrade de nginx, Fail2Ban, PHP sau distribuție.

9. Limitări

Regulile sunt un baseline și nu sunt universale. Pragurile pot afecta NAT-uri cu mulți utilizatori, boți legitimi, scanere autorizate, API-uri sau endpoint-uri Drupal cu trafic intens. Testarea, observabilitatea și o cale de rollback sunt obligatorii înainte de producție.

10. Documente asociate

- CONFIGURATION-REFERENCE-R0.md explică fiecare fișier și parametrii ajustabili;
- OPERATIONS-RUNBOOK-R0.md conține verificările zilnice, răspunsul la incidente și rollback-ul;
- CHANGELOG.md păstrează diferențele dintre versiunile publicate;
- ERNU_EU_Ghid_Drupal_Nginx_AntiDDoS_R0.pdf este ediția distribuibilă a acestui ghid.

11. Inventarul livrabilului

Componentă	Fișier principal	Rol
nginx global	nginx/conf.d/00-security-globals.conf	zone, limite, timeouts și formate de log
Real IP	nginx/conf.d/01-realip.conf	încredere explicită pentru CDN/LB
Virtual host	nginx/sites-available/drupal-site.conf	protecție și rutare Drupal

Componentă	Fișier principal	Rol
Corelator	scripts/security_log_processor.py	scor per IP și alertă normalizată
Test	scripts/test_attack_simulation.sh	simulare confirmată numai pe staging
Fail2Ban	fail2ban/filter.d, jail.d, action.d	deteție și ban temporar
nftables	nftables/00-ddos-base.nft	baseline L3/L4 recomandat
iptables	iptables/00-ddos-base-iptables.sh	alternativă pentru sisteme legacy
systemd	systemd/drupal-security-processor.service	execuție și hardening procesor

Referință de configurare

Versiune: 1.1 - 14 septembrie 2026

nginx

00-security-globals.conf

Parametru	Valoare implicită	Ajustare recomandată
general	10 cereri/s	trafic web obișnuit
login	2 cereri/s	autentificare și resetare parolă
api	30 cereri/s	JSON:API/REST; măsurați înainte de reducere
cron	1 cerere/minut	endpoint Drupal cron
perip	20 conexiuni	atenție la utilizatorii din spatele NAT
perserver	2.000 conexiuni	corelați cu workers, RAM și upstream
client_max_body_size	8 MiB	măriți numai pentru upload-uri necesare

\$binary_remote_addr trebuie să reprezinte clientul real. Dacă există CDN/LB, activați 01-realip.conf numai cu intervalele oficiale ale proxy-urilor de încredere. Nu permiteți arbitrar X-Forwarded-For.

drupal-site.conf

Înlocuiți obligatoriu:

- server_name drupal.ernu.sec;
- document root /var/www/drupal/web;
- căile certificatului TLS;
- socket-ul /run/php/php8.3-fpm.sock;
- IP-urile autorizate pentru install.php și update.php.

Configurația blochează dotfiles, PHP în directoarele de upload, directoare vendor și fișierele de proiect expuse accidental. Verificați compatibilitatea cu modulele Drupal și rutele API folosite de aplicație.

Corelatorul Python

Parametru	Implicit	Semnificație
ALERT_THRESHOLD	12	scorul minim pentru alertă
WINDOW_SECONDS	60	fereastra de corelare
COOLDOWN_SECONDS	300	interval minim între alerte pentru același IP
--log-path	security-events.log	intrarea produsă de nginx
--output-path	security-alerts.log	ieșirea citită de Fail2Ban

Modificarea ponderilor din SCORE_RULES trebuie justificată cu exemple din loguri sanitizate. O reducere prea agresivă poate bloca utilizatori legitimi.

Fail2Ban

Jail	maxretry	findtime	bantime
nginx-limit-req	15	60 s	1 h
nginx-botsearch	5	300 s	6 h
drupal-security-events	1	120 s	24 h

maxretry = 1 este intenționat pentru alerta agregată: pragul și corelarea au fost deja aplicate de procesor. Completați ignoreip cu adresele reale de administrare, VPN și monitorizare, fără intervale excesiv de largi.

Numele interne ale seturilor folosesc _ (nginx_limit, nginx_bots, drupal_critical) pentru compatibilitate cu identificatorii nftables.

Firewall

Alegeți o singură variantă:

- nftables: tabele izolate f2b_<name> pentru fiecare jail;
- iptables/ipset: set IPv4 și IPv6 separat pentru fiecare jail.

Regulile de bază limitează per IP rata SYN, ICMP și conexiunile noi către 80/443. Pragurile sunt baseline-uri, nu valori universale. Nu înlocuiți politica firewall existentă fără analizarea ordinii hook-urilor și lanțurilor.

Permiuni și logrotate

Procesorul rulează ca www-data:adm, cu ProtectSystem=strict și drept de scriere numai în /var/log/nginx. Configurația logrotate trebuie să recreeze:

```
create 0640 www-data adm
```

După orice modificare validați în această ordine:

```
python3 -m py_compile scripts/security_log_processor.py
bash -n scripts/test_attack_simulation.sh
bash -n iptables/00-ddos-base-iptables.sh
nft -c -f nftables/00-ddos-base.nft
nginx -t
fail2ban-client -t
```

Runbook operațional și rollback

Versiune: 1.1 - 14 septembrie 2026

Verificare după deployment

```
systemctl is-active nginx fail2ban drupal-security-processor
nginx -t
fail2ban-client -t
fail2ban-client status
tail -n 20 /var/log/nginx/security-events.log
tail -n 20 /var/log/nginx/security-alerts.log
```

Pentru nftables:

```
nft list tables
nft list table inet f2b_drupal_critical
```

Pentru iptables/ipset:

```
iptables -S INPUT
ipset list drupal_critical
```

Verificare periodică

Zilnic:

- starea celor trei servicii;
- rata răspunsurilor 429/403/404;
- IP-urile banate și fals-pozitivele raportate;
- spațiul disponibil pentru loguri.

Săptămânal:

- restarturi neașteptate ale procesorului;
- top motive/scoreuri din security-alerts.log;
- schimbări de trafic și endpoint-uri noi.

Trimestrial:

- pragurile nginx și SCORE_RULES;
- lista ignoreip;
- intervalele oficiale CDN/LB;
- testul complet pe staging și procedura de rollback.

Răspuns la blocarea unui utilizator legitim

1. identificați jail-ul și IP-ul din fail2ban-client status;
2. validați că IP-ul aparține utilizatorului/proxy-ului legitim;
3. păstrați logurile relevante pentru analiză;
4. executați unban numai în jail-ul corect;
5. ajustați cauza, nu adăugați automat intervale mari în allowlist.

```
fail2ban-client set drupal-security-events unbanip 203.0.113.7
```

Procesorul nu generează alerte

```
systemctl status drupal-security-processor
journalctl -u drupal-security-processor --since "30 minutes ago"
ls -l /var/log/nginx/security-events.log /var/log/nginx/security-alerts.log
```

Verificați: formatul logului nginx, permisiunile, existența evenimentelor relevante, rotația logurilor și pragul de scor.

Fail2Ban nu banează

```
fail2ban-client -t  
fail2ban-regex /var/log/nginx/security-alerts.log \  
  /etc/fail2ban/filter.d/drupal-security-events.conf  
fail2ban-client status drupal-security-events
```

Verificați acțiunea firewall selectată și faptul că nu sunt instalate simultan ambele variante de jail.

Rollback controlat

Mentineți o sesiune administrativă separată. Nu executați flush global asupra firewall-ului unui server accesat de la distanță.

1. dezactivați numai jail-urile adăugate de acest pachet;
2. reîncărcați Fail2Ban și confirmați jail-urile rămase;
3. opriți și dezactivați drupal-security-processor;
4. restaurați configurația nginx din backup, validați și reîncărcați;
5. eliminați doar tabela/seturile create de pachet;
6. restaurați politica firewall anterioară și verificați accesul.

Comenzi orientative:

```
systemctl disable --now drupal-security-processor  
nginx -t && systemctl reload nginx  
systemctl reload fail2ban
```

Documentați ora, cauza, comenzile executate și rezultatul fiecărui rollback.

Evidențe pentru incident

Păstrați, în conformitate cu politica organizației:

- timestamp și fus orar;
- IP-ul și jail-ul;
- liniile relevante din ambele loguri de securitate;
- scorul și motivele corelatorului;
- regula/setul firewall;
- modificările de configurare și aprobările asociate.

Sanitizați datele înainte de distribuire publică.

Changelog

1.1 - 2026-09-14

- integrare publică și sanitizată în catalogul repository-ului;
- adăugare ghid Markdown, referință de configurare și runbook operațional;
- sincronizare PDF cu documentația curentă;
- corectare regex Fail2Ban pentru timestamp-ul `nginx error.log`;
- izolare nftables per jail, pentru a evita ștergerea regulilor altor jail-uri;
- folosire de identificatori nftables compatibili, cu `_`;
- limitare SYN per IP sursă în locul unui prag global;
- validare HTTPS și confirmare explicită STAGING în scriptul de simulare;
- înlocuire exemple locale cu domenii și rețele rezervate documentației.

1.0 - 2026-09-14

- versiunea inițială a pachetului nginx, procesor Python, Fail2Ban, nftables/iptables și serviciu systemd.